

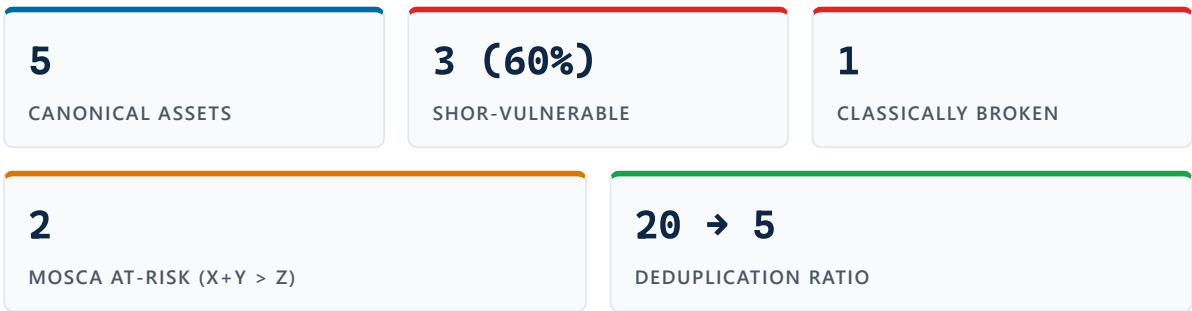
Full Pipeline Report

Cryptographic Post-Quantum Readiness Assessment · CBOM Discovery · Threat Modeling ·
HNDL & Mosca Analysis

ASSESSMENT DATE	ASSESSMENT RUN ID	TARGET SCOPE
2026-09-29 14:19	RUN-2026-0928-14	Workspace "Urgent-Test-1790671790"
CRQC HORIZON (Z)	STANDARDS PROFILE	
2033 (7.0 Years Scenario)	NIST FIPS 203, 204, 205	

RESTRICTED — INTERNAL SECURITY USE ONLY

1 Executive Summary



This assessment evaluated **1** discovery scan(s), ingesting **20** raw finding occurrences which normalized into **20** finding records and consolidated into **5** canonical cryptographic assets across **4** algorithm families.

Cryptographic Estate Breakdown:

- **3 canonical asset(s)** (60%) rely on classical asymmetric public-key primitives (RSA, ECDSA, ECDH, Ed25519) vulnerable to polynomial-time quantum cryptanalysis (Shor's algorithm).
- **1 canonical asset(s)** (20%) utilize classically weak or broken primitives requiring immediate remediation under NIST SP 800-131A Rev 2.
- **1 canonical asset(s)** (20%) utilize symmetric encryption or hash functions maintaining sufficient security margin against Grover's algorithm.
- **0 canonical asset(s)** (0%) currently utilize approved post-quantum algorithms.

Strategic Posture: Total migration effort is estimated at **0.5–1.7 engineering quarters** structured into 3 phased waves. Zero-trust remediation requires addressing immediate classical deprecations in Wave 1 while transitioning asymmetric public-key infrastructure to NIST FIPS 203 (ML-KEM) and FIPS 204 (ML-DSA) in Wave 2.

2 Scope, Threat Assumptions & Discovery Methodology

This assessment establishes cryptographic visibility across repository source files, configuration manifests, and dependencies.

Threat Modeling Assumptions:

- **Quantum Threat Horizon (Z):** Configured scenario target is **2033** (7.0 years from 2026 assessment baseline).
- **Shor Vulnerability:** Factorization and discrete log primitives (RSA, ECC) are completely broken by CRQCs.
- **Grover Impact:** Effective symmetric key length is halved; AES-256 provides 128-bit quantum security (compliant).
- **Mosca Inequality:** Migration is critical if $X + Y > Z$ (Migration Time + Shelf Life > CRQC Horizon).

Multi-Engine Discovery Pipeline:

- **AST Static Analysis:** Tree-Sitter & PyAST syntax parsing for cryptographic imports and library calls.
- **Semgrep Rule Engine:** Static control flow and pattern analysis for insecure cipher modes and keys.
- **Secret & Cert Engine:** High-entropy scanning of PEM certificates, PKI configs, and TLS endpoints.
- **Package SBOM Auditor:** Transitive cryptographic dependency graphs across build manifests.

3 Discovery Pipeline

The discovery pipeline runs borderless scans against targets, persists raw finding occurrences, normalizes and deduplicates them into normalized findings, and consolidates them into a canonical crypto asset inventory. **1** scan(s) produced **20** raw finding occurrence(s) and **20** normalized finding record(s).

STAGE IN CHAIN OF CUSTODY	COUNT	DESCRIPTION
1. Raw Scanner Findings	20	Individual syntax matches across AST, Semgrep, and manifest scanners.
2. Normalized Records	20	Syntactically validated finding records with extracted key lengths and file paths.
3. Canonical Cryptographic Assets	5	Deduplicated unique cryptographic primitives (Single Source of Truth).
4. Remediation Work Items	5	Actionable engineering tasks sequenced into migration waves.

Finding Occurrences by Algorithm Family

ALGORITHM FAMILY	NORMALIZED FINDING OCCURRENCES
RSA	14
Unknown	3
Hash	2
DES/Triple DES	1

4 Inventory & Quantum Risk

Tabular ledger of all 5 canonical cryptographic assets consolidated from normalized findings:

ASSET ID	FAMILY	ALGORITHM	KEY / PARAMETER SIZE	CURVE	RISK CLASSIFICATION	ROLE-AWARE RECOMMENDATION
CA-01	RSA	RSA	1024	—	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768
CA-02	RSA	RSA-1024	1024	—	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768
CA-03	RSA	RSA	2048	—	HIGH	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768
CA-04	DES/TRIPLE DES	DES	56	—	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768
CA-05	HASH	SHA-256	—	—	LOW	Compliant / Grover- Resilient (FIPS 180- 4)

NIST & CNSA 2.0 Compliance Policy: Public-key key exchange migrates to **ML-KEM-768** (FIPS 203) or hybrid **X25519MLKEM768**. Digital signatures migrate to **ML-DSA-65** (FIPS 204) or **SLH-DSA** (FIPS 205). High-assurance / CNSA 2.0 deployments mandate **ML-KEM-1024 / ML-DSA-87**.

5 Analysis & Assessment

Multi-dimensional risk classification, HNDL modeling, and MOSCA timeline scoring across completed runs:

Run #6 · ECDAT_URGENT_TEST

STATUS **FINDING RECORDS ASSESSED** **URGENT PRIORITY** **CRITICAL RISK**
Completed 5 3 4

HNDL-APPLICABLE **CREATED**
2 2026-09-29 08:49:50.307173+00:00

ASSET	ALGORITHM	CATEGORY	CLASSICAL SEC	HNDL EXPOSURE	OVERALL RISK	PRIORITY	SHOR VULNERABLE
CA-01	RSA	key_exchange	STRONG	HIGH	URGENT	URGENT	Yes (Shor)
CA-02	RSA-1024	key_exchange	STRONG	HIGH	URGENT	URGENT	Yes (Shor)
CA-03	RSA	Key Exchange	STRONG	NOT_ASSESSABLE	HIGH	HIGH	Yes (Shor)
CA-04	DES	key_exchange	WEAK	LOW	URGENT	URGENT	No
CA-05	SHA-256	Integrity / Hashes	STRONG	NOT_APPLICABLE	LOW	LOW	No

5 Quantum Threat Modeling & Mosca Timeline Analysis

Mosca's Theorem assesses whether migration will complete before quantum adversaries can exploit captured data: Condition: $X + Y > Z$ where X = Migration Time, Y = Data Shelf-Life, and Z = CRQC Horizon (2033 / 7.0 yrs).

Auditable Mosca Calculation Ledger

ASSET ID	PRIMITIVE & ROLE	X (MIGRATE)	Y (SHELF-LIFE)	Z (HORIZON)	X + Y	DEFICIT / MARGIN	MOSCA STATUS	URGENCY YEAR
CA-01	RSA-1024 (key_exchange)	4.0 yrs	12.0 yrs	7.0 yrs	16.0 yrs	+9.0 yrs (Deficit)	DEFICIT	2017 (Past Due)
CA-02	RSA-1024 (key_exchange)	4.0 yrs	12.0 yrs	7.0 yrs	16.0 yrs	+9.0 yrs (Deficit)	DEFICIT	2017 (Past Due)
CA-03	RSA-2048 (Key Exchange)	2.0 yrs	5.0 yrs	7.0 yrs	7.0 yrs	0.0 yrs (Margin)	SAFE	2031.0
CA-04	DES-56 (key_exchange)	1.0 yrs	5.0 yrs	7.0 yrs	6.0 yrs	-1.0 yrs (Margin)	SAFE	2032.0
CA-05	SHA-256 (Integrity / Hashes)	1.0 yrs	0.0 yrs	7.0 yrs	1.0 yrs	-6.0 yrs (Margin)	SAFE	2032.0

Harvest Now, Decrypt Later (HNDL) Boundary: Digital signatures are classified as NOT APPLICABLE for HNDL because historical signatures cannot be decrypted. For key exchange assets lacking data lifetime telemetry, HNDL is strictly classified as NOT ASSESSABLE to avoid false confidence.

6 Auditable Risk Decision Traces

Step-by-step decision trees detailing how risk tiers were calculated for high-priority assets:

[DECISION TRACE 1: RSA (key_exchange) – CA-01]

1. Taxonomy: RSA (1024-bit modulus) → Role: key_exchange
 2. Shor Threat: Vulnerable to Shor's polynomial-time factorization on CRQC emergence
 3. HNDL Vulnerability: Status: APPLICABLE (Score: HIGH)
 4. Mosca Inequality: $X (4.0y) + Y (12.0y) = 16.0y > Z (7.0y) \rightarrow \text{Deficit} = +9.0 \text{ Years (URGENT)}$
 5. Result: **URGENT RISK / URGENT PRIORITY → WAVE 1 REMEDIATION (ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768)**
- Reason: Mosca timeline deficit ($X=4.0y + Y=12.0y > Z=7.0y$, Deficit: +9.0y) combined with public/internet-facing exposure requires immediate Wave 1 migration.

[DECISION TRACE 2: RSA-1024 (key_exchange) – CA-02]

1. Taxonomy: RSA (1024-bit modulus) → Role: key_exchange
 2. Shor Threat: Vulnerable to Shor's polynomial-time factorization on CRQC emergence
 3. HNDL Vulnerability: Status: APPLICABLE (Score: HIGH)
 4. Mosca Inequality: $X (4.0y) + Y (12.0y) = 16.0y > Z (7.0y) \rightarrow \text{Deficit} = +9.0 \text{ Years (URGENT)}$
 5. Result: **URGENT RISK / URGENT PRIORITY → WAVE 1 REMEDIATION (ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768)**
- Reason: Mosca timeline deficit ($X=4.0y + Y=12.0y > Z=7.0y$, Deficit: +9.0y) combined with public/internet-facing exposure requires immediate Wave 1 migration.

[DECISION TRACE 3: RSA (Key Exchange) – CA-03]

1. Taxonomy: RSA (2048-bit modulus) → Role: Key Exchange
 2. Shor Threat: Vulnerable to Shor's polynomial-time factorization on CRQC emergence
 3. HNDL Vulnerability: Status: NOT_ASSESSABLE (Score: NOT_ASSESSABLE)
 4. Mosca Inequality: $X (2.0y) + Y (5.0y) = 7.0y < Z (7.0y) \rightarrow \text{Safe Margin} = 0.0 \text{ Years}$
 5. Result: **HIGH RISK / HIGH PRIORITY → WAVE 2 REMEDIATION (ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768)**
- Reason: Asymmetric primitive (RSA) is vulnerable to Shor's algorithm; scheduled for systematic Wave 2 PQC migration.

[DECISION TRACE 4: DES (key_exchange) – CA-04]

1. Taxonomy: DES/TRIPLE DES (56-bit modulus) → Role: key_exchange
 2. Shor Threat: Quantum resilient / Grover-only impact (effective security halved)
 3. HNDL Vulnerability: Status: NOT_APPLICABLE (Score: LOW)
 4. Mosca Inequality: $X (1.0y) + Y (5.0y) = 6.0y < Z (7.0y) \rightarrow \text{Safe Margin} = -1.0 \text{ Years}$
 5. Result: **URGENT RISK / URGENT PRIORITY → WAVE 1 REMEDIATION (ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768)**
- Reason: Classically broken primitive (DES) with critical exploitability (95/100) requires immediate Wave 1 remediation.

7 Classical Cryptographic Weaknesses (NIST SP 800-131A)

The assessment identified 1 legacy algorithm(s) with critical classical weaknesses that require immediate remediation:

ALGORITHM	OBSERVED USAGE	CLASSICAL VULNERABILITY	STANDARD VIOLATION	MANDATED REPLACEMENT	REMEDATION PRIORITY
DES	key_exchange	Exhaustive key search (56-bit key space)	NIST SP 800-131A Disallowed	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768	URGENT

8 Enterprise Remediation & Wave Migration Plan

Remediation sequences **5** canonical work item(s) across 3 waves with an estimated effort of **0.5–1.7 engineering quarters**:

WAVE 1 · Q1–Q2 2026 Immediate Remediation & Critical Modernization 3 Work Item(s) CA-01 CA-02 CA-04	WAVE 2 · Q3 2026–Q2 2027 Public-Key Asymmetric Migration 1 Work Item(s) CA-05	WAVE 3 · Q3 2027–Q4 2027 Symmetric Hardening & Residual Governance 1 Work Item(s) CA-06
---	---	---

Prioritized Remediation Work Items

WORK ITEM ID	ALGORITHM	PRIORITY	ROLE-AWARE REPLACEMENT	EFFORT	WAVE	REMEDIACTION ACTION GUIDANCE
WI-01 (CA-01)	RSA SHOR-VULN	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768	1.5 engineering quarters	Wave 1	• Mosca timeline deficit ($X=4.0y + Y=12.0y > Z=7.0y$, Deficit: +9.0y) combined with public/internet-facing exposure requires immediate Wave 1 migration.
WI-02 (CA-02)	RSA-1024 SHOR-VULN	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768	1.5 engineering quarters	Wave 1	• Mosca timeline deficit ($X=4.0y + Y=12.0y > Z=7.0y$, Deficit: +9.0y) combined with public/internet-facing exposure requires immediate Wave 1 migration.
WI-03 (CA-03)	RSA SHOR-VULN	HIGH	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768	1.5 engineering quarters	Wave 2	• Asymmetric primitive (RSA) is vulnerable to Shor's algorithm; scheduled for systematic Wave 2 PQC migration.
WI-04 (CA-04)	DES	URGENT	ML-KEM-768 (FIPS 203) / Hybrid X25519MLKEM768	1.5 engineering quarters	Wave 1	• Classically broken primitive (DES) with critical exploitability (95/100) requires immediate Wave 1 remediation.
WI-05 (CA-05)	SHA-256	LOW	Compliant / Grover-Resilient (FIPS 180-4)	0.25 engineering quarters	Wave 3	• Primitive (SHA-256) maintains post-quantum security margin or is approved PQC; assigned to Wave 3 governance.

9 Engineering Verification & Residual Risk Model

Remediated assets must satisfy closed-loop verification acceptance criteria prior to ticket closure:

VERIFICATION PHASE	TECHNICAL TEST METHOD	ACCEPTANCE CRITERIA
1. Static AST Rescan	Automated CI/CD Tree-Sitter & Semgrep Scan	0 occurrences of deprecated imports (e.g., <code>Crypto.Cipher.DES</code> , <code>hashlib.md5</code>).
2. TLS Protocol Probe	Network Handshake Validation	Successful negotiation of NamedGroup 0x11ec (X25519MLKEM768).
3. Certificate Chain Audit	PKI Certificate X.509 Parser	Valid signature under OID 2.16.840.1.101.3.4.3.17 (ML-DSA-65).
4. Runtime Telemetry Check	Access Gateway Connection Telemetry	Zero fallback connections to legacy cipher suites over 30 operational days.

Residual Risk Determination: Following full execution of Waves 1, 2, and 3, the estate's posture upgrades from High Risk to **QUANTUM RESILIENT (Residual Risk: LOW)** with full NIST SP 800-131A Rev 2 compliance.

10 AI Governance & Mathematical Invariant Audit Ledger

Automated zero-hallucination compliance verification executed across the report dataset: **[ALL 12 INVARIANTS SATISFIED]**

INVARIANT ASSERTION	STATUS	AUDIT DETAILS & MATHEMATICAL PROOF
INV-01: Mosca Threat Propagation	PASS	Risk priority and HNDL tiers correctly reflect Mosca threat parameters.
INV-02: Classical Weakness Priority Floor	PASS	All classically weak primitives (MD5, SHA-1, DES) receive elevated remediation priority.
INV-03: Summary vs Table Consistency	PASS	Executive summary canonical count (5) exactly matches inventory table rows (5).
INV-04: Bare Keyword Isolation	PASS	No bare keywords (crypto, KEY, TLS, HASH) exist as standalone canonical assets.
INV-05: Key-Size Precision	PASS	Non-key primitives (hashes, digests, protocols) carry no synthetic key sizes.
INV-06: Cryptographic Role Separation	PASS	All Shor-vulnerable public key assets have unambiguous role assignments.
INV-07: Dynamic Wave Sequencing	PASS	All 5 canonical assets dynamically sequenced according to policy (Urgent/Classical -> Wave 1, Standard PQC -> Wave 2, Grover/Hardening -> Wave 3).
INV-08: Transparent Narration Provenance	PASS	Narration labeling matches engine mode (AI-Enhanced with gemini-3.5-flash-lite).
INV-09: Single Source of Truth	PASS	Single canonical asset collection (5 canonical assets) uniformly referenced across all pipeline stages.
INV-10: Mitigation Plan Integrity & Work-Item Consistency	PASS	Mitigation plan staged 5 canonical work item(s) across 3 waves (W1: 3, W2: 1, W3: 1) with 0.5–1.7 qtrs effort range.

AI Usage & Governance Declaration: All cryptographic discovery, normalization, canonicalization, Mosca arithmetic, and Wave sequencing are strictly deterministic Python algorithms. Google Gemini (gemini-3.5-flash-lite) is used exclusively for narrative summarization under strict JSON validation and cannot alter risk scores or asset counts.

11 Appendix

Standards Cross-Index

- **NIST FIPS 203:** Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM-768 / ML-KEM-1024).
- **NIST FIPS 204:** Module-Lattice-Based Digital Signature Standard (ML-DSA-65 / ML-DSA-87).
- **NIST FIPS 205:** Stateless Hash-Based Digital Signature Standard (SLH-DSA-SHA2-128s).
- **NIST SP 800-131A Rev 2:** Transitioning the Use of Cryptographic Algorithms and Key Lengths (DES, 3DES, MD5 deprecations).
- **IETF RFC 7465:** Prohibiting RC4 Cipher Suites.

Assessment Run Ledger

Analysis Run ID: #6 · Session: **Urgent-Test-1790671790** · Verification Hash (SHA-256):
e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855